

CONF42 DEVSECOPS 2026

Would Your Alert Have Fired in Time?

GRADING DETECTION RULES AGAINST 46 REAL DEFI EXPLOITS

Aleksander Kryukov

SECURITY ENGINEER

Why DeFi

- 🌐 **Public.** Every on-chain step of every attack sits on a shared ledger.
- 🔒 **Immutable.** Nobody edits the record after the incident.
- 🕒 **Timestamped.** Every event has a block number and a time.
- ▶ **Replayable.** An archive node returns the exact state at any block.

\$3.4B

stolen in crypto thefts in 2025

Detection took one transaction. Protection took twenty minutes.

07:46 UTC

Exploit begins; monitoring flags it in the first transaction

08:06 UTC

Emergency controls trigger for the pools that can still be paused

08:07 UTC

Every pausable pool is paused: over \$19M protected

\$120M+

lost across Balancer and its forks

Older pools had outlived their pause window: there was nothing left to trigger.

Did it fire while there was still money to save?

Detection time

When the rule fires: the chain time of the triggering event, plus processing time

Response latency

How long from the alert until the mitigation takes effect

Mitigation availability

Whether the mitigation you rely on, such as a pause, still exists at that moment

Google's SRE Workbook grades alerts on four attributes:

Precision

Recall

Detection time

Reset time

46 incidents, chosen without looking at detection results



Each incident manifest holds

fork block

setup txs

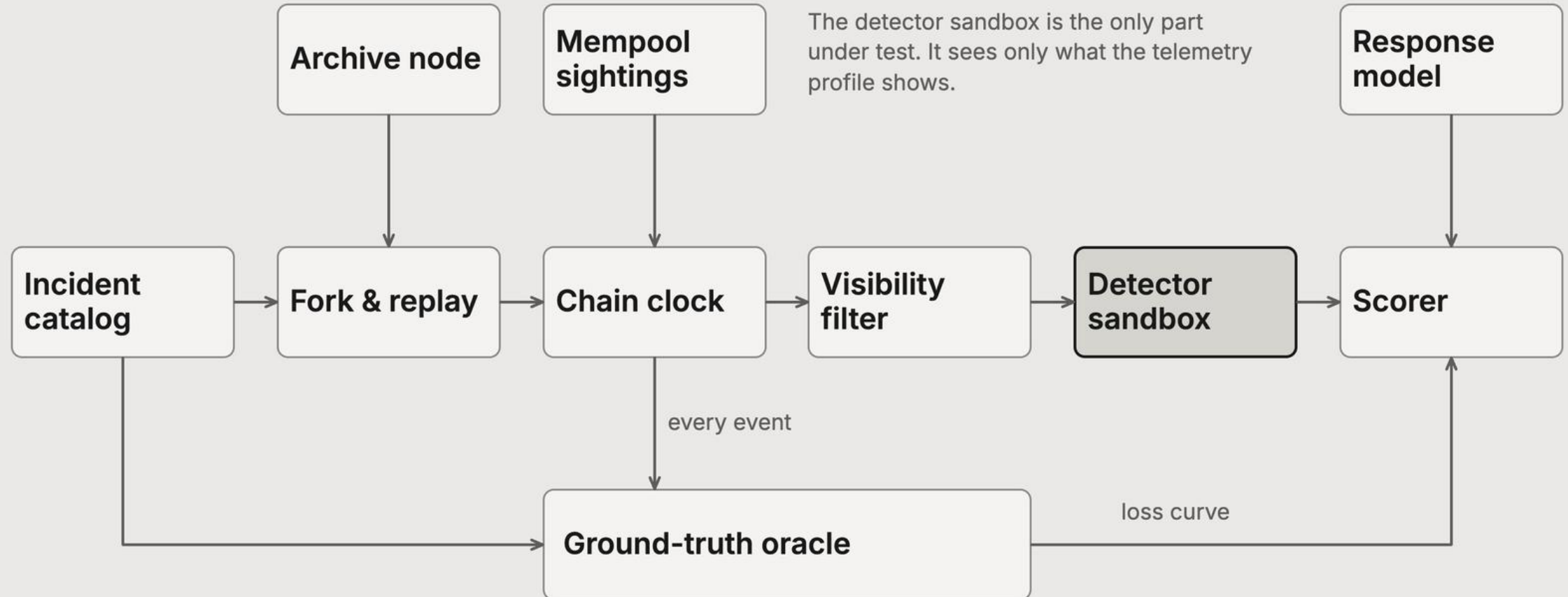
exploit txs

victim contracts

attacker cluster

stage label per event

Harness architecture



The replay runs the original transactions at their original blocks

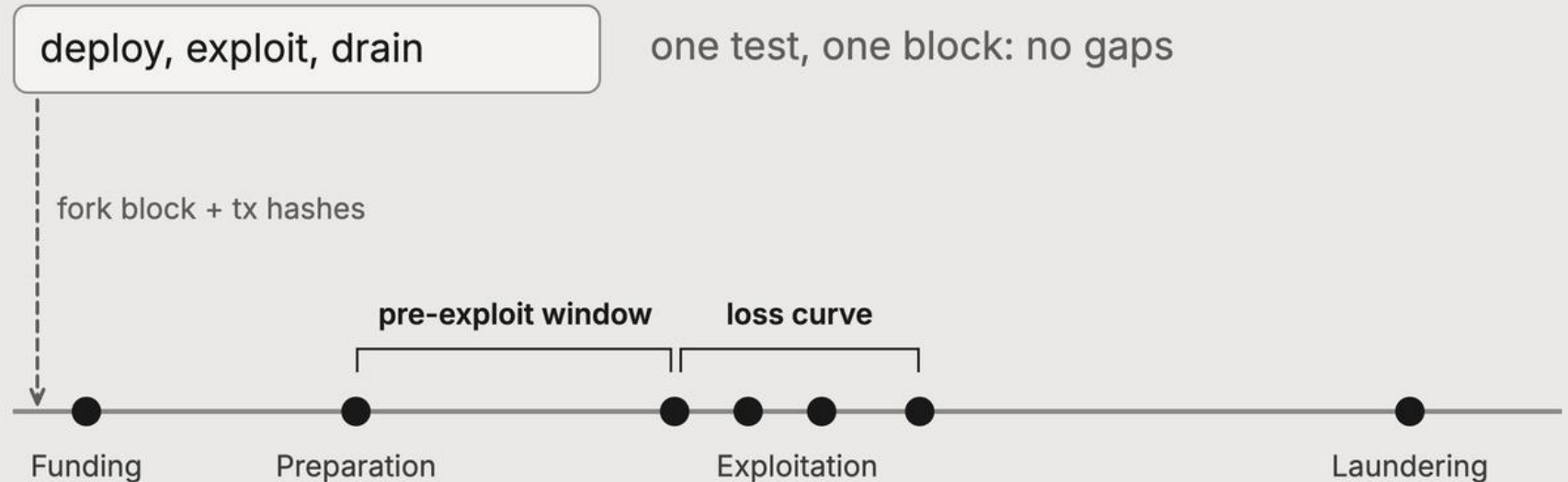
Proof of concept

deploy, exploit, drain

one test, one block: no gaps

Replay

original transactions at their original blocks



LOSS CURVES

Once an exploit starts, draining takes one block to over eight hours

Beanstalk · Apr 2022

\$182M in one transaction



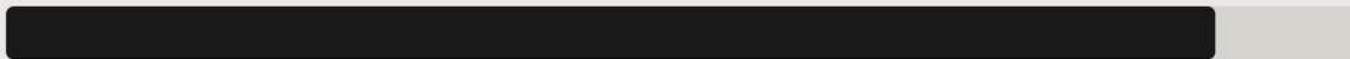
Harvest · Oct 2020

\$24M, 30 txs, under 7 min



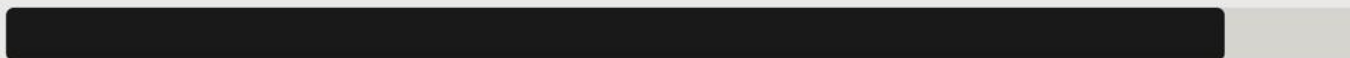
Nomad · Aug 2022

>\$186M, 960 txs, 8 h 17 min



Curve / Vyper · Jul 2023

pools drained from 13:10 until a whitehat rescue at 22:00 UTC



Log scale, from the first exploit transaction

6 s

1 min

10 min

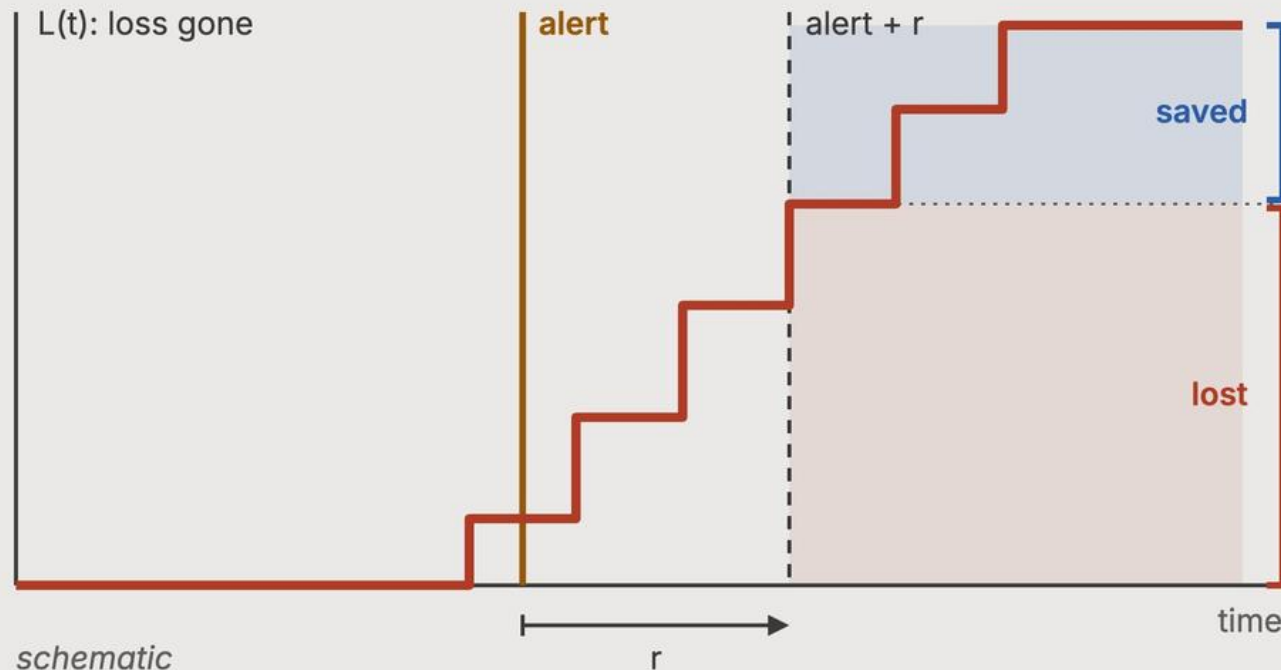
1 h

1 day

Ronin, drained in 2 transactions, went unnoticed for 6 days.

Sources: ImmuneFi (Beanstalk) · ImmuneBytes, SlowMist (Harvest) · Coinbase (Nomad) · LlamaRisk (Curve) · Ronin post-mortem

Each incident's deadline comes from its own loss curve



$L(t)$

Share of the incident's final loss already gone at time t

$\text{saved} = 1 - L(\text{alert} + r)$

What is still inside when a mitigation with latency r takes effect

$\text{deadline}(p) = t(L=p) - r$

The latest alert that keeps the loss below a share p

Euler Finance: an alert 3 minutes before a \$197M drain

T – 10 min

08:43 UTC: attacker funded through Tornado Cash; funding and malicious-contract alerts fire

T – 3 min

Attack Detector raises an early warning

T

\$197M drained

“Too fast for the standard manual response of a multisig.”

Forta, on why the pre-exploit alerts did not stop the drain

KILL-CHAIN STAGES

When the curve is a step, the window is before the exploit



LOOKAHEAD · FSE 2025

> **60%**

of attacks leave at least 100 s between deploying the attack contract and the first attack transaction

7.3%

run entirely inside the constructor, so deployment and attack are one transaction with no window

BEANSTALK · APR 2022

24 h

the malicious proposal sat on-chain for a day before the \$182M attack

Six incidents, graded from post-mortems

Incident	Detection	Response	Mitigation	Outcome
Euler, Mar 2023	Alerts 10 min and 3 min before the exploit	Manual multisig: too slow	No automated shutoff on the alerts	\$197M drained
Balancer, Nov 2025	Flagged in the first transaction	Emergency controls after 20 min	Pause only within the pause window	Over \$19M protected; \$120M+ lost
Curve / Vyper, Jul 2023	First pool drained at 13:10 UTC	No pause documented; Curve update on Discord at 20:23 UTC	Whitehat front-run of the last drain	2,879.65 ETH returned
Ronin bridge, Mar 2022	Found by a user after 6 days	Bridge halted on day 6	None: 5 of 9 keys were enough	\$624M lost; users repaid
Sonne, May 2024	Team aware after ~25 min	Markets paused after ~25 min	The timelock was the attack path	~\$20M lost; \$6.5M protected
KyberSwap, Nov 2023	Confirmed within the hour	New liquidity blocked after 1 h 38 min	Partial: new liquidity only	~\$55M taken; ~\$5.9M recovered

Incidents not included in the table: Prisma 2024, Rari/Fei 2022, UwU Lend 2024, Inverse 2022, Platypus 2023 and others.

FALSE-POSITIVE BUDGETING

In live use, about 1 flag in 5 was a real attack

23,463

new contracts analysed

→ **129**

flagged as adversarial

→ **26**

confirmed attack contracts

SAME MODEL, IN THE LAB

Precision 92.9% · recall 86.7% · false-positive rate 0.16%

VENDOR CLAIM

Forta: under 1% of protocols would ever be paused by a false positive

Budget false actions by how hard they are to undo

Notify

A human decides what to do
Euler 2023: the warning came first; a manual pause was too slow

Throttle

Outflow capped per time window
ERC-7265 circuit-breaker proposal

Pause

All later outflow stops, while the pause window lasts
Balancer 2025: pools past their pause window could not be paused

Freeze

Attacker funds stopped at chain level
Cetus 2025: Sui validators froze \$162M

easy to undo · larger budget

hard to undo · budget shrinks to zero

A rule may drive a tier only if its benign alert rate fits that tier's budget. Irreversible tiers get a budget of zero: a human decides.

The blind spot is growing

10.6% → 41.2%

of DeFi attacks used private transactions: Jun 2021 – Sep 2022 (20 of 189) vs Sep 2022 – Dec 2023 (35 of 85)

2.45% → 7.86%

of all Ethereum transactions were private each month, same two periods

> 50%

of Ethereum gas went to private transactions by August 2024

Which rules still see an attack sent privately

Rule family	Needs mempool	First sees a private attack at
Pre-inclusion simulation	Yes	At inclusion: too late to front-run
Match rules	No	The exploit transaction, once included
Stage correlator	No	Funding and deployment, already on-chain
Contract classifier	No	Deployment, unless the attack runs in the constructor (7.3% of attacks)
Outflow-rate limit	No	Inside the exploit transaction, as funds leave

Without the mempool: pause after the first attack transaction

A private transaction can't be simulated before it lands. But over 90% of attacks take more than one transaction (BlockSec count), so pausing after the first still protects the rest.

The same questions, asked of your pipeline

In the DeFi lab	In your pipeline
Archive node	Retained raw telemetry
Block-by-block replay	Recorded telemetry replayed through detection-as-code in CI
Loss curve	Time until data is stolen
Pause, circuit breaker	Auto-remediation: disable a key, isolate a host
Private mempool	Telemetry you don't collect

29 min

average eCrime breakout time in 2025; the fastest took 27 s

22%

of incidents had data stolen in under an hour in 2025, up from 19%

Takeaways

Replay before you ship.

Run every rule against recorded incidents, block by block, before it goes live.

Grade time against the loss curve.

Record when each rule fired and how much was still saveable at that moment.

Budget false positives by reversibility.

Its measured false-alert rate decides which action a rule may drive.

Map your blind spots.

Measure the telemetry you lack, and move detection to stages you can still see.

CONF42 DEVSECOPS 2026

Thank you

Aleksander Kryukov

